

ACTIVIDAD 06:

Cartografiando el pentesting: análisis comparativo de metodologías de seguridad informática

Universidad Politécnica de San Luis Potosí

Materia:

CNO V Seguridad Informática

Estudiante:

Avalos Rangel Hazel Mario 181801

Profesor:

Mtro. Servando López Contreras

Fecha de entrega:

13 – Febrero – 2026

Prueba de pentesting	Descripción breve de la metodología	Fases de implementación	Objetivo principal	Escenarios en los que se utiliza	Orientación	Autores u organismos responsables	URL del material oficial	Existencia de certificaciones asociadas	Versiones o actualizaciones vigentes
MTRE ATT&CK	Conjunto de matrices de tácticas, técnicas y sub-técnicas de adversarios.	Las fases dependen de la matriz, las cuales son Enterprise, ICS y Mobile. Cada una cuenta con diferentes fases de implementación.	Aprender sobre TTP (Tácticas, Técnicas y Procedimientos) de adversarios.	Preparación de ataques, explotación y post-explotación.	Defensiva y ofensiva.	MITRE	https://attack.mitre.org/	No existen certificaciones oficiales.	Actualización constante de cada matriz y sus respectivas técnicas.
OWASP WSTG	Es una guía detallada y completa centrada en la seguridad de aplicaciones web.	1. Antes de que comience el desarrollo. 2. Durante la definición y diseño. 3. Durante el desarrollo. 4. Durante el despliegue 5. Durante el mantenimiento y las operaciones.	Detectar vulnerabilidades en aplicaciones web.	Pentesting web, auditorías de software.	Seguridad de aplicaciones web.	OWASP	https://owasp.org/www-project-web-security-testing-guide/	OWASP Testing Guide, OWASP Top 10.	La versión más reciente es la 4.2 lanzada el 13 de diciembre del 2020.
NIST SP 800-115	Guía de la industria sobre planificación y realización de pruebas de seguridad.	1. Planeación. 2. Ejecución. 3. Post-ejecución.	Proporcionar pautas sobre seguridad de la información.	Estándar de la industria para orientación de pentesting.	Metodología para evaluaciones de seguridad de la información.	National Institute of Standards and Technology (NIST).	https://csrc.nist.gov/publications/detail/sp/800-115/final	No tiene certificación, se usa como guía de referencia en auditorías y estándares de seguridad.	La versión más reciente es la SP 800-115 lanzada en septiembre del 2008.

OSSTMM	Documento que establece pruebas de seguridad repetibles y uniformes.	1. Definir alcance y reglas del test 2. Ejecutar pruebas por canales (humano, físico, red) 3. Medición RAV. 4. Reportar mediante STAR (Security Test Audit Report)	Establecer métricas de seguridad operativa y análisis de confianza.	Pentesting empresarial, Evaluación de seguridad física y humana, Telecomunicaciones y redes.	Operativa y técnica.	Pete Herzog, ISECOM	https://www.ise.com.org	• OPST • OPSA • OPSE • OWSE	OSSTMM versión 3.02 lanzada el 14 de diciembre del 2010.
PTES	Estándar que provee información sobre tipos de ataques, métodos y herramientas.	1. Interacciones previas al compromiso 2. Recopilación de inteligencia 3. Modelado de amenazas 4. Análisis de vulnerabilidades 5. Explotación 6. Post-explotación 7. Informes	Estandarizar la ejecución de pruebas de penetración.	Pentesting empresarial.	Ofensiva.	PTES	http://www.pentest-standard.org	OSCP, eJPT relacionadas.	Estándar estable sin versión formal.
ISSAF	Metodología para evaluar seguridad de sistemas, redes y controles.	1. Recopilación de información 2. Asignación de red 3. Identificación de vulnerabilidades 4. Penetración 5. Obtener acceso y escalamiento de privilegios 6. Más enumeración 7. Comprometer a usuarios / sitios remotos 8. Mantener el acceso 9. Cubriendo las pistas	Evaluación exhaustiva de la seguridad de sistemas de información.	Auditorías corporativas y pentesting.	Auditoría y ofensiva.	Open Information Security Group (OISSG)	https://pymesec.org/issaf/	No existen certificaciones oficiales.	Versión vigente lanzada en el 2004

Bibliografía

Cisco Networking Academy. (2026). *1.2 Exploración de las metodologías de pruebas de penetración. Cisco Networking Academy | Seguridad Informática-Hacker ético.* <https://www.netacad.com/launch?id=3b07bfc3-9b21-4dbd-909ba235416df136&tab=curriculum&view=3d7507ef-98e1-51ac-b1026bdb7618f7a4>

Herzog, P. (2010). *OSSTMM 3. ISECOM.* <https://www.isecom.org/OSSTMM.3.pdf>

MITRE Corporation. (2026). ATT&CK. MITRE ATT&CK. <https://attack.mitre.org>

National Institute of Standards and Security (NIST). (septiembre de 2008). *NIST SP 800-115 Technical Guide to Information Security Testing and Assessment. CSRC NIST.* <https://csrc.nist.gov/pubs/sp/800/115/final>

OISSG. (30 de abril de 2006). *Information Systems Security Assessment Framework Open Information Security Group (OISSG). PYMESEC.* <https://pymesec.org/issaf/>

OWASP. (2026). *OWASP Web Security Testing Guide. OWASP.* <https://owasp.org/www-project-web-security-testingguide/>

PTES. (16 de agosto de 2014). *Main Page. PentTest Standard.* http://www.penteststandard.org/index.php/Main_Page